可行性评估与技术方案

独立域名与客户品牌方案

新客户使用自己的域名访问现有系统。登录页展示该客户的 Logo、系统名称和浏览器标签图标。应用和数据库继续共用，为客户创建独立租户，并把域名绑定到该租户。

日期	2026年11月12日	文档性质	可行性评估与技术方案
需求来源	客户《独立域名与客户品牌方案》	评估结论	可以实现

01 结论

可以实现。新客户继续使用现在这一套应用和数据库。为客户创建独立租户，把客户域名绑定到该租户；用户从该域名进入时，系统切换到对应的品牌，并只接受该租户的账号登录。原域名和现有客户的使用方式保持不变。

未列入配置的域名在反向代理层拒绝，请求不进入应用，页面上不会出现其他客户的品牌或数据。

继续沿用	本次增加
现有应用与数据库	租户品牌配置：域名、系统名称、登录页 Logo、浏览器图标
原域名的登录方式	按网关校验后的访问域名识别租户
现有租户与企业权限	客户域名上的账号、会话和跳转限制
单套服务的部署方式	反向代理中的客户域名与 HTTPS 证书
平台管理员维护配置	上传和修改的审计记录

> 说明 本方案依据需求说明里描述的现状编写：系统已有租户与企业权限、云盘链接、认证回调和网关。编写时没有对照业务代码逐项核对。看到代码后，需要把本文的设计落到具体的表、接口和调用点上。

02 需求提炼

下面八条覆盖客户说明中的方案概述和五项主要改动。

01 独立域名，系统继续共用

新客户用自己的域名访问。系统仍共用现有应用和数据库，为该客户创建独立租户，并把域名绑定到这个租户。

02 登录页展示客户品牌

登录页显示客户 Logo、系统名称和浏览器标签图标。

03 品牌配置由平台管理员维护

保存客户域名、系统名称、登录页 Logo 和浏览器图标。上传和修改留下审计记录。

04 客户域名只接受本租户账号

新客户域名仅接受绑定租户的账号。登录、退出和跳转始终留在当前域名。原域名的登录方式保留。

05 按校验后的域名加载品牌

品牌根据经过网关校验的访问域名加载。未配置的域名不展示其他客户的品牌或数据。

06 绝对地址兼容客户域名

会生成完整网址的功能要能用在客户域名上，其中包括云盘链接和认证回调。

07 沿用现有权限，并验证隔离

继续使用现有的租户及企业权限控制，针对文件和接口检查隔离是否生效。

08 解析到现有服务，只信任代理传入的域名

客户域名解析到现有服务。在反向代理中配置域名和 HTTPS 证书。应用只信任由代理传入的域名信息，避免伪造的请求头生效。

03 技术方案

3.1 请求如何进入系统

需求里的网关由现有反向代理承担。代理先确认域名在配置内，再把域名交给应用。应用按域名找到租户，品牌、登录和业务接口都读这个结果。数据仍写在现有数据库里，按租户隔离。

- 客户域名。以 CNAME 指向现有服务。
- 反向代理。完成 HTTPS，核对域名是否已配置，覆盖写入域名请求头。
- 域名中间件。放在全部业务逻辑之前，按域名解析租户并写入请求上下文。
- 业务处理。品牌展示、登录校验、文件和接口访问都使用该租户上下文。
- 数据。现有数据库。读写继续走现有的租户与企业权限。

域名分三种处理。

原域名	已绑定的客户域名	未配置的域名
走现有登录和默认品牌。现有客户的用法不变。	进入对应租户，展示该客户的品牌，只接受该租户账号。	在代理层拒绝，请求不进入应用。

3.2 数据模型

品牌与域名分开存放。一个租户可以绑定多个域名，一个域名只属于一个租户。

租户品牌	说明
tenant_id	关联现有租户，一条租户一条品牌配置
system_name	系统名称，用于登录页和浏览器标题
logo_url	登录页 Logo 的访问地址
favicon_url	浏览器标签图标的访问地址
enabled	是否启用
维护信息	创建人、修改人、创建时间、修改时间

租户域名	说明
domain	客户域名。小写保存，唯一。不含协议、路径和端口
tenant_id	绑定的租户
enabled	该域名是否生效

Logo 和图标文件放进现有文件服务，数据库只记录地址。另建审计表，记录操作人、时间、动作（新增、修改、停用），以及修改前后的内容。

3.3 域名识别

- 反向代理用覆盖的方式写入 Host 和 X-Forwarded-Host，不用追加，避免客户端自带的值残留。
- 应用端口只接受反向代理的连接，不直接对公网开放。应用只采用代理写入的域名。
- 中间件放在全部业务逻辑之前。比较前把域名转成小写，不把协议、路径和端口算进去。
- 解析结果可以缓存。品牌或域名保存后，删除对应域名的缓存。
- 原域名不查客户品牌，继续走现有逻辑。

3.4 品牌加载

- 提供一个免登录接口，按当前域名返回系统名称、Logo 地址和图标地址。原域名返回默认品牌。
- 这个接口只返回展示用的字段。
- 页面标题和图标在服务端输出 HTML 时写入，避免先闪出默认品牌再替换。
- 上传只接受 PNG、JPEG、ICO，并限制文件大小。不接受 SVG，避免文件中携带脚本。

3.5 登录与会话

- 在客户域名下，账号所属租户必须和该域名绑定的租户相同。
- 不匹配时，返回与密码错误相同的提示，不单独透露账号是否存在。
- 会话中记录租户。之后每个请求都核对：会话里的租户与当前域名的租户一致。
- Cookie 不设置 Domain，只发给当前主机，避免被其他域名带上。
- 登录成功、退出、未登录时的跳转使用相对路径。回跳地址只接受以单个斜杠开头的站内路径。

3.6 绝对地址

增加一个统一的取站点根地址的方法。根地址只从本次请求里已经校验过的域名拼出，形式为 https://当前域名。代码里写死的站点域名改为调用这个方法。需要排查的位置：

- 云盘的分享链接和下载链接

- 认证回调地址
- 邮件、短信里的链接
- 跨域白名单、CSRF 来源校验、WebSocket 来源校验
- 文件和 CDN 地址

3.7 反向代理与证书

示例为 Nginx。换成其他反向代理时，保持同样三条：覆盖域名头、拒绝未配置的域名、应用不直接暴露。

```
server {
    listen 443 ssl;
    server_name app.customer.com;

    ssl_certificate     /path/customer.crt;
    ssl_certificate_key /path/customer.key;

    location / {
        proxy_set_header Host              $host;
        proxy_set_header X-Forwarded-Host  $host;
        proxy_set_header X-Forwarded-Proto $scheme;
        proxy_pass http://app_upstream;
    }
}

server {
    listen 443 ssl default_server;
    ssl_reject_handshake on;
}
```

- 客户把域名用 CNAME 指到现有服务。
- `X-Forwarded-Host` 由 `proxy_set_header` 覆盖写入。
- 未配置的域名由 `default_server` 拒绝 TLS 握手。
- 证书可以由客户提供，也可以由服务端通过 ACME 自动签发和续期。

3.8 隔离验证

上线前跑完下面的用例。前五条用来确认客户之间互不可见，最后一条确认现有客户不受影响。

编号	操作	期望
T1	租户 A 的账号在租户 B 的域名上登录	登录失败。提示与密码错误相同
T2	把原域名签发的会话拿到客户域名上访问接口	请求被拒绝
T3	用客户域名的会话，按标识访问其他租户的文件和接口	请求被拒绝，不返回对方数据
T4	不经过代理，直接携带伪造的 Host 或 X-Forwarded-Host 访问应用	连接不被接受，伪造的域名头不生效
T5	使用未配置的域名访问	代理层拒绝。响应中不出现任何客户的品牌或数据
T6	现有客户从原域名登录，使用云盘，走认证回调	行为与现在一致

3.9 实施顺序

顺序	工作	完成标志
1	数据与域名入口	品牌表、域名表、审计表可用。请求能按域名解析到租户，未配置域名进不了应用
2	登录页品牌	用客户域名打开登录页，立即显示该客户的名称、Logo 和图标
3	登录与会话	其他租户的账号不能在该域名登录。登录、退出和跳转不离开当前域名
4	绝对地址	云盘链接、认证回调和消息链接使用当前域名
5	管理与审计	平台管理员可以维护品牌和域名。上传与修改写入审计
6	上线与回归	证书和代理生效。第 3.8 节用例通过。原域名流程回归通过

04 风险与待确认

待确认 **第三方登录的回调域名**

如果现有登录接了微信、钉钉或企业 SSO，对方平台通常要求事先登记回调地址。客户域名需要逐个登记；或者统一回调到原域名，再用一次性票据跳回客户域名。两条路的改动范围不同，要按现有登录方式选定。这是最可能超出本文范围的一块。

待确认 **新客户账号能否从原域名登录**

需求写明了客户域名只接受该租户的账号，没有写该租户的账号是否仍可从原域名登录。两种做法的账号入口不同，需要客户确认。

风险 **现有接口的租户过滤是否完整**

本方案依赖现有的租户和企业权限。独立域名不能补上接口里漏掉的租户条件。第 3.8 节的 T3 用来把这类遗漏找出来，找到后在对应接口补上租户条件。

待确认 **证书由谁申请、由谁续期**

证书可以由客户提供，也可以由服务端用 ACME 自动签发和续期。这决定上线步骤和日后的运维责任，需要在配置第一个客户域名之前定下来。

看到业务代码之后，对照本文核对登录与会话的实现、绝对地址的生成位置、现有租户模型，以及网关配置，再列出具体的改动文件、接口和表结构。